SEMANA 16 · PARTE 1

De modelo a agente: qué cambia en la operación

Parte 1 de 4 · Unidad 3

Ing. Rodolfo Cañas Cervantes
Universidad de la Costa (CUC) · Ingeniería de Sistemas
Semana 16 · Periodo 2026-2 · Barranquilla, Colombia

Un modelo responde; un agente además actúa

Herramientas, memoria y planificación: tres piezas que convierten una respuesta en una acción.

Qué agrega un agente a un modelo



MODELO

responde una pregunta

HERRAMIENTAS

consulta datos y ejecuta

MEMORIA

recuerda el contexto

PLAN

encadena pasos hacia un objetivo

El salto de responder a actuar es el que cambia el perfil de riesgo.

Fuente: NIST AI Risk Management Framework; OWASP (seguridad de aplicaciones web) GenAI Security Project

Qué puede hacer un agente en un centro de operaciones

Leer, resumir, enriquecer y proponer: tareas repetitivas donde el volumen supera a las personas.

Cuatro tareas típicas

LEER
miles de eventos por hora

RESUMIR
el caso en tres líneas

ENRIQUECER
sumar contexto de activo e identidad

PROPONER
una prioridad y un siguiente paso

NO HACER
decidir sin verificación

MEDIR
aciertos y errores del agente

El valor del agente está en el volumen; el riesgo, en la decisión.

Fuente: NIST SP 800-61 Rev. 3; MITRE (matrices ATT&CK y ATLAS) ATT&CK; OWASP GenAI

El triage: donde se acumulan las alertas

Más detección no sirve si el equipo no alcanza a revisar: la cola crece y las alertas se ignoran.

El embudo del triage



Una alerta que nadie mira es peor que una alerta que no existe: da falsa tranquilidad.

Fuente: NIST SP 800-61 Rev. 3; MITRE ATT&CK

PRIORIZACIÓN

Cómo prioriza un agente

Contexto del activo, identidad implicada, gravedad del fallo y momento: cuatro señales que ordenan la cola.

Señales que suben o bajan la prioridad

ACTIVO
crítico o
de prueba

IDENTIDAD
privilegiada o
de servicio

SEÑAL
fallo conocido
y explotable

MOMENTO
horario y
ventana de cambio

HISTORIA
ya se había
visto antes

IMPACTO
qué se afecta
si es real

La prioridad no sale del modelo: sale de las reglas de negocio que le dimos.

Fuente: NIST SP 800-61 Rev. 3; MITRE D3FEND

Los límites: alucinación y confianza

Un modelo puede inventar un dato con total seguridad; en seguridad, un dato inventado cuesta caro.

Tres límites que hay que asumir

ALUCINACIÓN

inventa datos

con seguridad

CONTEXTO

no sabe lo que

no se le dio

CORTE

su conocimiento

tiene fecha

PROMPT INJECTION

texto malicioso

lo desvía

OPACIDAD

no explica bien

su razonamiento

CONSECUENCIA

hay que verificar

siempre

Un dato inventado con seguridad es más peligroso que un dato faltante.

Fuente: OWASP Top 10 for LLM Applications; NIST AI RMF

Prompt injection: cuando el dato trae instrucciones

Un correo, un registro o un nombre de archivo pueden contener órdenes dirigidas al agente.

El ataque al propio defensor



El agente lee datos de terceros: cualquier texto que lea es una entrada potencialmente hostil.

Fuente: OWASP Top 10 for LLM Applications (prompt injection); MITRE ATLAS

Niveles de autonomía

De asistir a actuar solo hay cuatro escalones, y cada uno exige más control y más registro.

Cuatro niveles y su control



Cada escalón de autonomía debería ganarse con evidencia de aciertos, no con una demo.

Fuente: NIST AI Risk Management Framework; NIST SP 800-61 Rev. 3

Tres usos donde el agente ya aporta valor

Resumir un caso, enriquecer una alerta y buscar patrones: tareas acotadas, con resultado verificable.

Usos con resultado comprobable

RESUMEN

un caso largo en tres líneas

ENRIQUECIMIENTO

contexto de activo e identidad

BÚSQUEDA

patrones en registros

VENTAJA

velocidad en volumen

REQUISITO

datos de calidad y trazabilidad

LÍMITE

no sustituye el juicio

El mejor primer uso es el que se puede comprobar en un minuto: un resumen o una búsqueda.

Fuente: NIST SP 800-61 Rev. 3; MITRE ATT&CK; OWASP GenAI

Cómo se mide un agente de triage

Precisión, tiempo de verificación y tasa de corrección: sin métricas, la autonomía es una opinión.

Tres métricas mínimas

PRECISIÓN

cuántas prioridades fueron correctas

COBERTURA

cuántas alertas procesó

TIEMPO

cuánto ahorra por caso

CORRECCIÓN

cuántas veces lo corrigió el humano

FALSOS NEGATIVOS

casos reales que dejó pasar

DERIVA

si empeora con el tiempo

La métrica que más importa es la de corrección: mide cuántas veces el humano dijo no.

Fuente: NIST AI RMF (medición); NIST SP 800-61 Rev. 3

Gobernanza: registrar cada decisión

Quién decidió, con qué datos, qué se ejecutó y quién lo aprobó: sin ese registro no hay responsabilidad.

Qué debe quedar registrado

ENTRADA
qué datos vio el agente

PROPUESTA
qué recomendó y por qué

APROBACIÓN
quién lo autorizó

ACCIÓN
qué se ejecutó de verdad

RESULTADO
qué pasó después

REVISIÓN
quién lo auditó y cuándo

Si no se puede reconstruir la decisión, no se puede atribuir responsabilidad.

Fuente: NIST AI RMF; NIST SP 800-61 Rev. 3; Ley 1581 de 2012

CASO

Caso ilustrativo: la alerta que el agente cerró

Caso de clase, no es una empresa real: el agente descartó una alerta real por un dato inventado.

La secuencia del error



Ningún dato inventado se detecta sin abrir la fuente original.

Fuente: caso ilustrativo de clase; sin datos de una empresa real y sin cifras

Síntesis de la Parte 1

Un agente lee, resume y propone; la decisión de responder sigue siendo humana y verificable.

Lo que cambia y lo que no



QUÉ CAMBIA

volumen y velocidad



QUÉ NO CAMBIA

la responsabilidad es humana



QUÉ HACE FALTA

registro y métricas



QUÉ SE ESPERA

menos ruido, misma cautela

Con esto claro, la parte 2 entra al flujo completo: del evento a la decisión.

Fuente: NIST AI RMF; NIST SP 800-61 Rev. 3; OWASP GenAI

Qué no se delega a un agente

Cuatro decisiones que deben quedar en manos de una persona, aunque el sistema sea muy bueno.

La lista de lo que no se automatiza

SANCIONAR
a una persona
por un hallazgo

CERRAR CASOS
sin revisión de
la evidencia

CAMBIAR POLÍTICA
reglas que afectan
a todos

BORRAR DATOS
irreversible y
sin vuelta

RAZÓN
el costo del error
recae en alguien

REGLA
si no se revierte
fácil, no se delega

Si la acción no se puede revertir en minutos, no debería ejecutarla un agente.

Fuente: NIST AI RMF; Ley 1581 de 2012; NIST SP 800-61 Rev. 3

Cómo cambia el trabajo del analista

Menos tiempo clasificando y más tiempo investigando: el turno cambia de forma, no desaparece.

El turno antes y después

ANTES

horas leyendo alertas repetidas

DESPUÉS

revisión de casos complejos

NUEVA TAREA

verificar al agente

NUEVA TAREA 2

ajustar reglas y umbrales

RIESGO

confianza excesiva

CLAVE

rotar la revisión manual

El analista no desaparece: cambia de tarea, y necesita nuevas habilidades.

Fuente: NIST SP 800-61 Rev. 3; NIST AI RMF

SEMANA 16 · PARTE 2

Del evento a la decisión verificable

Parte 2 de 4 · Unidad 3

Ing. Rodolfo Cañas Cervantes
Universidad de la Costa (CUC) · Ingeniería de Sistemas
Semana 16 · Periodo 2026-2 · Barranquilla, Colombia

Anatomía de una alerta enriquecida

Un evento con contexto: qué activo, qué identidad, qué amenaza y qué se sabe de casos parecidos.

De evento suelto a alerta útil



Sin contexto, una alerta es un número; con contexto, es una decisión posible.

Fuente: NIST SP 800-61 Rev. 3; MITRE ATT&CK

Enriquecer: consultar antes de opinar

Inventario, directorio, reputación y casos previos: cuatro consultas que cambian la lectura de un evento.

Las cuatro consultas del enriquecimiento

INVENTARIO
qué es ese activo
y quién responde

DIRECTORIO
qué cuenta es y
si es privilegiada

REPUTACIÓN
si la dirección
es conocida

HISTÓRICO
si ya pasó y
qué se hizo

FUENTE
de dónde sale
cada dato

FALLO
qué pasa si la
consulta falla

Un enriquecimiento sin fuente es una opinión con formato de dato.

Fuente: NIST SP 800-61 Rev. 3; MITRE D3FEND

Priorizar con criterio explícito

Reglas escritas y auditables: si la prioridad no se puede explicar, no se puede defender.

Reglas que se pueden auditar

CRITICIDAD
del activo afectado

PRIVILEGIO
de la cuenta implicada

SEÑAL
fuerza de la evidencia

HORA
momento del día

HISTORIA
casos previos iguales

EXPLICACIÓN
por qué esa prioridad

Si la regla no está escrita, la prioridad del agente es indefendible ante una auditoría.

Fuente: NIST SP 800-61 Rev. 3; NIST AI RMF

APROBACIÓN

El agente propone, el humano dispone

Separar la propuesta de la ejecución es el control más simple y el más efectivo de todo el diseño.

El punto de control



La aprobación no es un clic de trámite: es el punto donde alguien asume la responsabilidad.

Fuente: NIST AI RMF; NIST SP 800-61 Rev. 3

Playbook: qué puede tocar el agente

Lista cerrada de acciones permitidas, cada una con su condición y su reversión.

Acciones y sus condiciones

PERMITIDAS
consultar, etiquetar
y notificar

CON APROBACIÓN
bloquear cuenta
o aislar host

PROHIBIDAS
borrar datos o
cambiar políticas

REVERSIÓN
cómo se deshace
cada acción

REGISTRO
quién ejecutó
y cuándo

LÍMITE
una acción por
caso, no en cadena

Una lista cerrada de acciones es más segura que un agente con criterio amplio.

Fuente: NIST SP 800-61 Rev. 3; MITRE D3FEND

DETECCIÓN

Cómo saber que el agente se equivocó

Revisar una muestra al azar y comparar con el resultado real: el método más simple y el más honesto.

Control de calidad del agente

MUESTREO

revisar casos al azar

CONTRASTE

comparar con la decisión humana

REGISTRO

marcar los desacuerdos

CAUSA

dato faltante o regla mal escrita

CORRECCIÓN

ajustar la regla o la fuente

FRECUENCIA

revisión periódica

Sin muestreo periódico, la precisión del agente es una creencia, no un dato.

Fuente: NIST AI RMF (medición y monitoreo)

Deriva: cuando el agente deja de funcionar

Los datos cambian, las reglas envejecen y el desempeño baja sin que nadie lo note.

Por qué se degrada un sistema que funcionaba

DATOS
cambia el tráfico
o el inventario

REGLAS
dejan de reflejar
la política

MODELO
versión nueva
o proveedor distinto

ENTORNO
nuevos servicios
y ataques

SEÑAL
suben las
correcciones

RESPUESTA
revalidar y
recalibrar

La deriva no avisa: se detecta comparando el desempeño de hoy con el de hace tres meses.

Fuente: NIST AI RMF (monitoreo continuo); NIST SP 800-61 Rev. 3

Evaluar antes de desplegar

Un conjunto de casos con respuesta conocida: sin eso, no hay forma de comparar versiones.

El banco de pruebas mínimo

CASOS REALES
anonimizados y con respuesta

CASOS DIFÍCILES
los que confunden a los humanos

CASOS HOSTILES
con texto de inyección

LÍNEA BASE
resultado del equipo humano

MÉTRICA
precisión y tiempo

REPETICIÓN
mismo set en cada versión

Sin conjunto de pruebas, comparar dos versiones del agente es comparar impresiones.

Fuente: NIST AI RMF; NIST SP 800-115 (método de prueba)

ERRORES

Cinco errores al desplegar un agente

Confiar en la demo, no medir, darle acciones de más, ignorar la inyección y no registrar.

Los tropiezos más frecuentes

CONFIAR EN LA DEMO

funciona en el ejemplo, no en la cola

NO MEDIR

sin métricas no hay mejora

DAR ACCIONES

permisos que no necesita

IGNORAR INYECCIÓN

leer datos de terceros sin filtro

NO REGISTRAR

sin traza no hay responsabilidad

NO CAPACITAR

el equipo no sabe cuándo desconfiar

Casi todos los fracasos vienen de dar por sentado lo que no se verificó.

Fuente: NIST AI RMF; OWASP LLM Top 10; NIST SP 800-61 Rev. 3

Ética y responsabilidad del agente

Alguien responde por cada acción: si no está claro quién, el diseño está incompleto.

Tres preguntas de responsabilidad

QUIÉN RESPONDE

por una acción automática

CON QUÉ DATOS

qué se usó y qué se descartó

QUÉ SE COMUNICA

al afectado y cuándo

TRANSPARENCIA

explicación comprensible

RECURSO

cómo se revierte una decisión

LÍMITE

no automatizar sanciones

Un agente puede ejecutar; la responsabilidad no se delega a un sistema.

Fuente: NIST AI RMF; Ley 1581 de 2012; Ley 1273 de 2009

El Laboratorio 9, próximamente

Se publica con su guía: un flujo de triage con propuesta automática y aprobación humana registrada.

Lo que va a pedir el laboratorio

ENTORNO
alertas de práctica

REGLAS
criterios escritos y auditables

PROPUESTA
el agente sugiere una prioridad

APROBACIÓN
un humano decide y firma

REGISTRO
traza de la decisión

MÉTRICA
aciertos y correcciones

Sin fecha ni pasos todavía: la guía se publica con el laboratorio, no antes.

Fuente: guía del Laboratorio 9 (próximamente)

Síntesis de la Parte 2

Leer, enriquecer, proponer, aprobar y registrar: un flujo con un punto humano en el medio.

El flujo completo



LEER

eventos en volumen



ENRIQUECER

con fuentes verificables



PROPONER

prioridad y siguiente paso



APROBAR

humano decide y firma

Con el flujo claro, la parte 3 hace el repaso de la unidad completa.

Fuente: NIST SP 800-61 Rev. 3; NIST AI RMF; OWASP GenAI

Cuánto ahorra de verdad

El ahorro se mide contra el trabajo manual, incluyendo el tiempo de verificar la propuesta.

La cuenta honesta del ahorro



El ahorro real incluye el tiempo de verificar: si no se cuenta, la métrica miente.

Fuente: NIST AI RMF (medición); NIST SP 800-61 Rev. 3

El equipo y el agente

Un agente no reemplaza turnos: cambia el reparto del trabajo y exige capacitación explícita.

Lo que hay que definir con el equipo

QUIÉN APRUEBA
un rol claro por turno

CUÁNDO DESCONFIAR
señales de que la propuesta falla

CÓMO CORREGIR
dónde se registra el desacuerdo

CAPACITACIÓN
qué se practica sin el agente

ROTACIÓN
revisión manual periódica

CULTURA
el error se reporta, no se oculta

Un equipo que no puede trabajar sin el agente es un equipo vulnerable.

Fuente: NIST AI RMF; NIST SP 800-61 Rev. 3

SEMANA 16 · PARTE 3

Repaso de la unidad: lo que hay que llevarse

Parte 3 de 4 · Unidad 3

Ing. Rodolfo Cañas Cervantes
Universidad de la Costa (CUC) · Ingeniería de Sistemas
Semana 16 · Periodo 2026-2 · Barranquilla, Colombia

MAPA

La unidad completa en una imagen

De las herramientas a los agentes: cinco semanas que se apoyan una sobre otra.

El recorrido de la Unidad 3



Fuente: plan de la Unidad 3 del curso

Semana 12: el entorno y sus herramientas

Procesos, red, archivos y registros: lo que se necesita saber mirar antes de defender algo.

Lo esencial de la semana 12

PROCESOS

qué corre y

con qué permisos

RED

interfaces, rutas

y puertos

ARCHIVOS

permisos y

propietarios

REGISTROS

dónde se escribe

qué

PAQUETES

qué se instala

y desde dónde

SERVICIOS

qué arranca

solo

Sin saber mirar el sistema, cualquier herramienta de seguridad es un adorno.

Fuente: material de la semana 12; NIST SP 800-115

Semana 13: la denegación de servicio

Tres familias, tres métricas y un principio: sin línea base no hay umbral que valga.

Lo esencial de la semana 13



VOLUMEN

satura el enlace

bps



PROTOCOLO

agota tablas

pps



APLICACIÓN

consume el servicio

rps



LÍNEA BASE

qué es normal

en tu red



UMBRAL

por origen y

ventana



VERIFICAR

el cliente legítimo

sigue en pie

El ataque golpea la disponibilidad: la defensa se diseña, no se improvisa.

Fuente: Lab 6 v1.0.4; RFC 9293 (TCP)

Semana 13: las dos reglas y la palabra over

La regla de Suricata cuenta por origen; la de nftables descarta solo lo que supera el límite.

Los dos detalles que más se olvidan

THRESHOLD
count y seconds: por origen

SIN RECARGAR
la regla nueva no se aplica

LIMIT RATE
con la palabra over

SIN OVER
descartas al legítimo

CT COUNT
conexiones simultáneas

SET DINÁMICO
bloqueo con expiración

Un error de una palabra en nftables invierte el efecto de la regla.

Fuente: Lab 6 v1.0.4, secciones 3 y 4

Semana 14: la IA en la defensa

Un modelo aprende la línea base y detecta lo que se sale del patrón, sin reglas escritas a mano.

Lo que aporta la detección con modelos

APRENDE

la línea base de la red

DETECTA

lo que se sale del patrón

NO ESCRIBE

reglas a mano

VENTAJA

variantes no previstas

COSTO

datos y mantenimiento

LÍMITE

explica poco y deriva

El modelo no reemplaza las reglas: cubre lo que las reglas no alcanzan a describir.

Fuente: NIST AI RMF; Gartner (NDR); material S14

Semana 14: la IA en el ataque

Phishing más creíble, voces y rostros falsos, y modelos atacados con instrucciones ocultas.

Lo que cambia para el defensor

PHISHING

texto convincente y personalizado

DEEPFAKE

voz e imagen falsas

ESCALA

menos esfuerzo por ataque

PROMPT INJECTION

instrucciones ocultas

SEÑAL

canal alterno de verificación

DEFENSA

procedimiento, no solo filtro

Contra un engaño creíble, el control es un procedimiento: verificar por otro canal.

Fuente: OWASP LLM Top 10; MITRE ATLAS; material S14

Semana 14: SASE (acceso seguro al borde) y confianza cero

Verificar cada acceso, desde cualquier lugar, con políticas en la nube y no en el perímetro.

El cambio de modelo de red

PERÍMETRO
antes: dentro
era confiable

CONFIANZA CERO
cada acceso
se verifica

SASE
políticas y control
en la nube

IDENTIDAD
el nuevo
perímetro

VENTAJA
acceso remoto
controlado

RIESGO
depende de la
configuración

El perímetro se movió: ahora la identidad es lo que hay que proteger.

Fuente: Gartner (SASE); NIST SP 800-53 Rev. 5; material S14

Hilo conductor: la disponibilidad

Todo lo que hicimos se puede leer como la pregunta de si el servicio está cuando se necesita.

De la teoría a la práctica



La disponibilidad no es un tema de una semana: es la pregunta que ordena la unidad.

Fuente: elaboración propia a partir de la Unidad 3

Hilo conductor: observar antes de configurar

Medir, registrar y comparar: los tres pasos que evitan configurar a ciegas.

El método que se repite en cada semana



MEDIR

qué es normal

aquí y ahora

REGISTRAR

dejar rastro

de lo observado

COMPARAR

detectar la

diferencia

DECIDIR

configurar con

criterio

Configurar sin medir es adivinar con herramientas caras.

Fuente: Lab 6 v1.0.4; NIST SP 800-61 Rev. 3

Hilo conductor: autorización y ética

El permiso escrito y la proporcionalidad: sin eso, la habilidad técnica es un problema.

La frontera que atraviesa la unidad



PERMISO

escrito y firmado



PROPORCIÓN

lo mínimo necesario



EVIDENCIA

registro de lo hecho



CONFIDENCIALIDAD

no divulgar ni reutilizar

La diferencia entre un profesional y un delincuente no es técnica: es la autorización.

Fuente: Ley 1273 de 2009; NIST SP 800-115

Preguntas de repaso (1 de 2)

Seis preguntas para autoevaluarse antes del cierre de la unidad.

Preguntas para responder en voz alta

1 · TRES FAMILIAS

¿cuál es la métrica de cada una?

2 · LÍNEA BASE

¿por qué se mide antes de configurar?

3 · OVER

¿qué pasa si falta esa palabra?

4 · MODELO

¿qué aporta frente a una regla fija?

5 · PROMPT INJECTION

¿por qué el dato trae instrucciones?

6 · PERMISO

¿qué debe decir la autorización?

Si alguna respuesta no sale, ese es el tema que hay que repasar.

Fuente: elaboración propia a partir de la Unidad 3

Las respuestas cortas

Lo que se espera oír: una frase por pregunta, sin siglas y sin rodeos.

Respuestas de referencia

1 · bps, pps, rps
volumen, protocolo y aplicación

2 · sin base
no hay umbral válido

3 · invierte
descarta al legítimo

4 · variantes
no previstas por las reglas

5 · lee datos
de terceros hostiles

6 · activos
nombrados, con vigencia y firma

Una respuesta correcta cabe en una frase: si necesita cinco, el tema no está claro.

Fuente: elaboración propia a partir de la Unidad 3

CIERRE

Síntesis de la Parte 3

Tres hilos: disponibilidad, observación y autorización: la unidad se sostiene en esos tres.

Lo que atraviesa las cinco semanas



Con los hilos claros, la parte 4 cierra con el repaso de las dos últimas semanas.

Fuente: elaboración propia a partir de la Unidad 3

Errores frecuentes de la unidad

Seis tropiezos que aparecieron en los laboratorios y que conviene no repetir.

Lo que más costó en la unidad

UMBRAL COPIADO
sin medir la línea base

SIN RECARGAR
la regla no se aplicó

FALTA OVER
descartó al legítimo

PORTAFOLIO VACÍO
evidencia no guardada

ACEPTAR LO FÁCIL
entregar la salida del escáner

NO LEER
el diagrama antes de actuar

Casi todos los errores de la unidad tienen la misma causa: saltarse la medición.

Fuente: elaboración propia a partir de los laboratorios de la unidad

SEMANA 16 · PARTE 4

Cierre de la unidad y del curso

Parte 4 de 4 · Unidad 3

Ing. Rodolfo Cañas Cervantes
Universidad de la Costa (CUC) · Ingeniería de Sistemas
Semana 16 · Periodo 2026-2 · Barranquilla, Colombia

Semana 15: el marco de la prueba

Permiso, método, ambiente y evidencia: la prueba se sostiene en el proceso, no en la herramienta.

Lo esencial de la prueba de seguridad

PERMISO
alcance escrito y firmado

MÉTODO
fases con entregables

AMBIENTE
riesgo acordado con el dueño

INFORME
hallazgos con evidencia

PROPORCIÓN
lo mínimo para demostrar

CONFIDENCIALIDAD
no divulgar ni reutilizar

La herramienta la corre cualquiera; el criterio y el permiso son del profesional.

Fuente: NIST SP 800-115; Ley 1273 de 2009; OWASP WSTG

Semana 15: reconocer, analizar y cerrar

Observar lo público, inventariar con permiso, verificar sin explotar y cerrar superficie después.

Del reconocimiento a la defensa



OBSERVAR

dominios y DNS públicos

INVENTARIAR

hosts y servicios con permiso

VERIFICAR

el fallo con el mínimo

CERRAR

reducir la superficie

El mismo conocimiento sirve para atacar y para defender: la diferencia es el permiso.

Fuente: MITRE ATT&CK TA0043; NIST SP 800-53 Rev. 5

Semana 16: agentes, en una frase

Un agente lee, resume, enriquece y propone; un humano verifica y decide, y todo queda registrado.

El resumen de hoy

LEE

volumen que

no se alcanza

PROPONE

prioridad y

siguiente paso

VERIFICA

un humano

decide

REGISTRA

traza de la

decisión

MIDE

aciertos y

correcciones

LIMITA

acciones

permitidas

El agente aporta velocidad; el humano aporta responsabilidad.

Fuente: NIST AI RMF; NIST SP 800-61 Rev. 3; OWASP GenAI

Hilo conductor: la verificación humana

En cada semana hay un punto donde alguien confirma: el cliente sigue en pie, el hallazgo es real, el agente no inventó.

Dónde aparece la verificación

S13
el cliente legítimo
sigue respondiendo

S14
el modelo no
sustituye el juicio

S15
el hallazgo se
confirma a mano

S16
el humano aprueba
la acción

PATRÓN
siempre hay un
punto humano

REGLA
si no se puede
verificar, no se usa

Un control que no se puede verificar no es un control: es una esperanza.

Fuente: elaboración propia a partir de la Unidad 3

CASO

Caso integrador: un incidente en cadena

Caso de clase, no es una empresa real: del escaneo al flood y a la decisión del agente, en una sola historia.

Las semanas encadenadas



S15

escaneo y hallazgo

S13

flood contra el servicio

S16

el agente propone

CIERRE

humano decide y registra

Un incidente real combina todo lo que vimos: por eso la unidad se estudia completa.

Fuente: caso ilustrativo de clase; sin datos de una empresa real y sin cifras

Preguntas de repaso (2 de 2)

Seis preguntas sobre las dos últimas semanas, para cerrar la autoevaluación.

Preguntas para responder en voz alta



7 · ALCANCE

¿qué cuatro cosas debe nombrar?



8 · CVSS

¿qué describe y qué no?



9 · AGENTE

¿en qué se diferencia de un modelo?



10 · INYECCIÓN

¿por qué el dato puede mandar?



11 · AUTONOMÍA

¿qué escalón exige más control?



12 · DERIVA

¿cómo se detecta que empeoró?

Estas seis cubren las semanas 15 y 16: si salen, la unidad está cerrada.

Fuente: elaboración propia a partir de la Unidad 3

Glosario de la unidad

Diez términos que resumen la unidad, de línea base a verificación humana.

El vocabulario que hay que conservar



LÍNEA BASE

qué es normal en tu red



UMBRAL

cuenta por origen y ventana



LIMIT RATE OVER

descarta solo lo que sobra



NDR (detección y respuesta en red)

detección de red con modelos



PROMPT INJECTION

dato que trae instrucciones



TRIAGE

priorizar la cola de alertas



ALCANCE

qué se prueba y qué no



HALLAZGO

fallo con evidencia

Si puedes explicar estos ocho términos, tienes la unidad completa.

Fuente: elaboración propia a partir de la Unidad 3

Referencias de la unidad

Lab 6 v1.0.4, NIST SP 800-61 y 800-115, OWASP, MITRE ATT&CK y ATLAS, y la Ley 1273.

Las fuentes que sostienen la unidad

LAB 6 v1.0.4
guía del laboratorio de DoS

NIST SP 800-61
respuesta a incidentes

NIST SP 800-115
pruebas de seguridad

OWASP
aplicaciones y LLM Top 10

MITRE ATT&CK
tácticas y técnicas

LEY 1273
delitos informáticos en Colombia

Documentación primaria, con versión y fecha: eso es lo que se cita en un informe.

Fuente: compilación de fuentes de la Unidad 3

Competencias que desarrollaron

Cinco cosas que ya saben hacer, y que pueden demostrar con evidencia de los laboratorios.

Lo que se llevan del curso

OBSERVAR

medir y comparar tráfico real

DETECTAR

escribir reglas con criterio

MITIGAR

aplicar límites sin dañar

PROBAR

verificar con método

ANALIZAR

modelos y sus límites

DOCUMENTAR

informe con evidencia

Una competencia se demuestra con evidencia, no con una afirmación en una hoja de vida.

Fuente: elaboración propia a partir de la Unidad 3; NIST SP 800-115

Qué guardar en el portafolio

Tres artefactos por laboratorio: el enunciado que resolviste, la evidencia y tu informe.

Los artefactos que sirven después

EVIDENCIA
el archivo del laboratorio

INFORME
tu análisis, no el de otro

REGLAS
tus reglas, con comentarios

CAPTURAS
con contexto y fecha

REFLEXIÓN
qué falló y qué aprendiste

LÍMITE
nada de datos reales

Un portafolio con evidencia vale más que una lista de herramientas que conoces.

Fuente: elaboración propia a partir de la Unidad 3

Siguientes pasos

Practicar en casa, profundizar en una rama y mantener el hábito de documentar: tres caminos concretos.

Por dónde seguir

PRACTICAR

laboratorios propios en casa

PROFUNDIZAR

una rama: red, aplicación o datos

DOCUMENTAR

cada práctica con evidencia

CERTIFICAR

cuando haya base práctica

COMUNIDAD

grupos y divulgación

ÉTICA

el marco, siempre presente

El siguiente paso no es una certificación: es practicar con método y documentar lo que haces.

Fuente: ENISA (ciberseguridad y formación); NIST NICE Framework

Cierre del curso

Dieciséis semanas después, la idea central es la misma: seguridad es criterio, no solo herramientas.

Las ideas que me llevo



MEDIR

antes de

configurar

VERIFICAR

antes de

confiar

AUTORIZAR

antes de

actuar

DOCUMENTAR

siempre

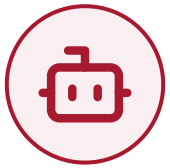
Gracias por el semestre: lo que sigue lo construyen ustedes, con método y con ética.

Fuente: elaboración propia; NIST SP 800-115; Ley 1273 de 2009

Síntesis final de la Unidad 3

Cinco semanas, cuatro hilos y una conclusión: la seguridad se practica con método y se demuestra con evidencia.

El cierre de la unidad



5 SEMANAS

de Linux a los agentes



4 HILOS

disponibilidad, observación, ética y verificación



1 MÉTODO

medir, verificar, autorizar, documentar



1 PREGUNTA

¿está el servicio cuando se necesita?

Fin de la Unidad 3. Lo que sigue se comunica por los canales oficiales del curso.

Fuente: elaboración propia a partir de la Unidad 3

Preguntas abiertas del campo

Cuatro debates que siguen sin respuesta y que van a encontrar si trabajan en esto.

Lo que todavía no está resuelto

AUTONOMÍA
¿cuánto se puede delegar?

EXPLICABILIDAD
¿basta una explicación parcial?

RESPONSABILIDAD
¿quién responde por el modelo?

DATOS
¿con qué datos se entrena sin sesgo?

REGULACIÓN
cambia más rápido que la técnica

CRITERIO
la respuesta no es solo técnica

Son preguntas abiertas: la respuesta se construye con criterio, no con una herramienta nueva.

Fuente: NIST AI RMF; ENISA; OWASP GenAI